

Mitigação de Ataques

Objetivo da Aula

Apresentar os principais meios utilizados para mitigar os riscos das redes, entender a importância de uma política de segurança da informação, conhecer os principais mecanismos de proteção à rede e aos dispositivos finais, mecanismos de autenticação e criptografia.

Apresentação

Mitigar os riscos em uma rede é aplicar tecnologias, procedimentos e pessoas, a fim de reduzir a probabilidade ou o impacto em relação a um determinado risco. Nesta aula, você verá como a segurança da informação divide a rede em camadas e como são aplicadas estratégias de mitigação de risco para cada uma delas.

1. Segurança em Camadas

A maioria das organizações emprega uma abordagem de defesa profunda (também conhecida como abordagem em camadas). Isso requer uma combinação de dispositivos e serviços de rede trabalhando em conjunto para proteger roteadores, switches, servidores, serviços de rede, processos e pessoas.

2. Política de Segurança

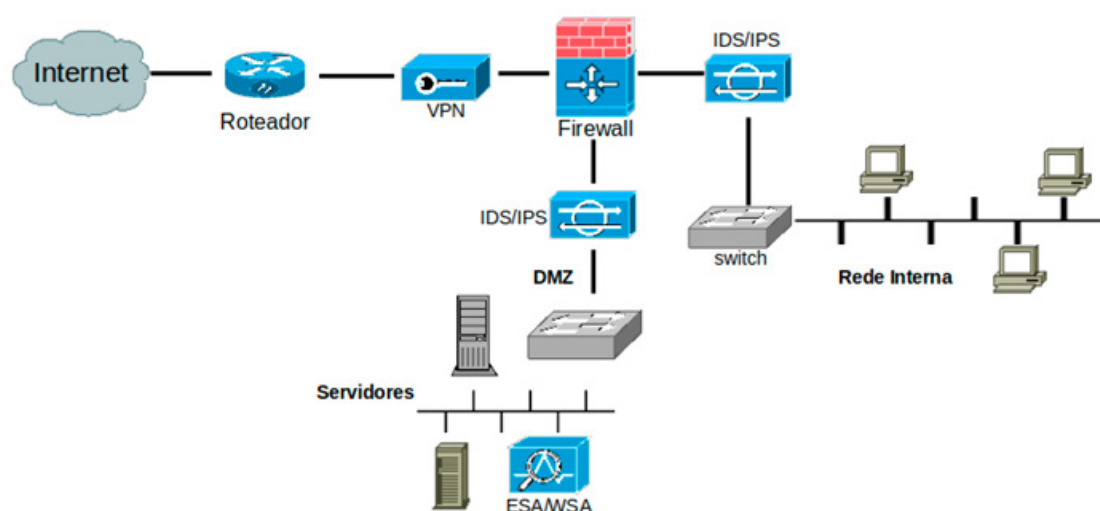
As políticas de segurança têm por objetivo informar usuários, funcionários e parceiros sobre os requisitos de uma organização para proteger seus ativos de tecnologia e informação, além de especificar um conjunto de diretivas para atender a estes requisitos, fornecendo uma base a partir da qual todas as ações relacionadas à informação deverão estar em conformidade, como aquisição, configuração e auditoria sistemas e redes de computadores. Dentre as diretivas abordadas em uma política de segurança, podemos citar:

- política de identificação e autenticação – especifica como pessoas autorizadas que podem ter acesso a recursos de rede e procedimentos de verificação de identidade;
- políticas de senha – garante que as senhas atendam aos requisitos mínimos de complexidade e vigência;
- política de uso de aplicativos (AUP – **Acceptable Use Policy**) – identifica os aplicativos e usos de rede que são aceitáveis para a organização e as ações em caso de violação;
- política de acesso remoto – define como os usuários remotos podem acessar uma rede e que serviços podem ser utilizados por meio de conectividade remota;
- políticas de Manutenção de Rede – especifica procedimentos de atualização de sistemas operacionais dos dispositivos de rede e de aplicativos de usuário final;
- procedimentos de tratamento de incidentes – descreve como os incidentes de segurança são tratados.

3. Mitigando Riscos na Borda da Rede

Podemos designar a borda da rede como toda a interface da rede interna com as redes externas, seja a internet ou a rede corporativa. A figura 1 apresenta uma topologia típica de uma rede conectada à internet. Aqui encontramos tecnologias que irão tratar todos os dados que entram e saem da rede.

Figura 1: Topologia típica de uma rede com acesso à internet

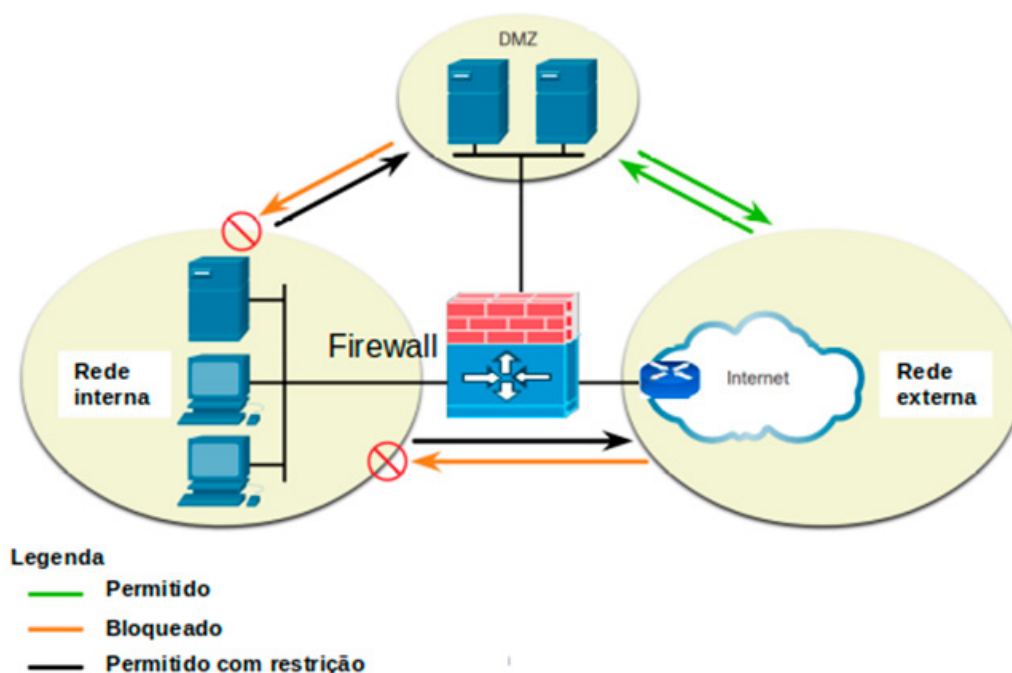


Fonte: elaboração própria (2023).

3.1. Firewall

Firewalls são dispositivos que atuam por padrão nas camadas 3 e 4 do modelo OSI, controlando as conexões que entram e saem da rede, garantindo que o tráfego interno possa sair e voltar e que o tráfego externo possa ir apenas onde desejado, por exemplo, os servidores da DMZ, porém não podendo iniciar conexões com hosts internos. A figura 2 apresenta esquematicamente o funcionamento do firewall.

Figura 2: Esquema de funcionamento do firewall

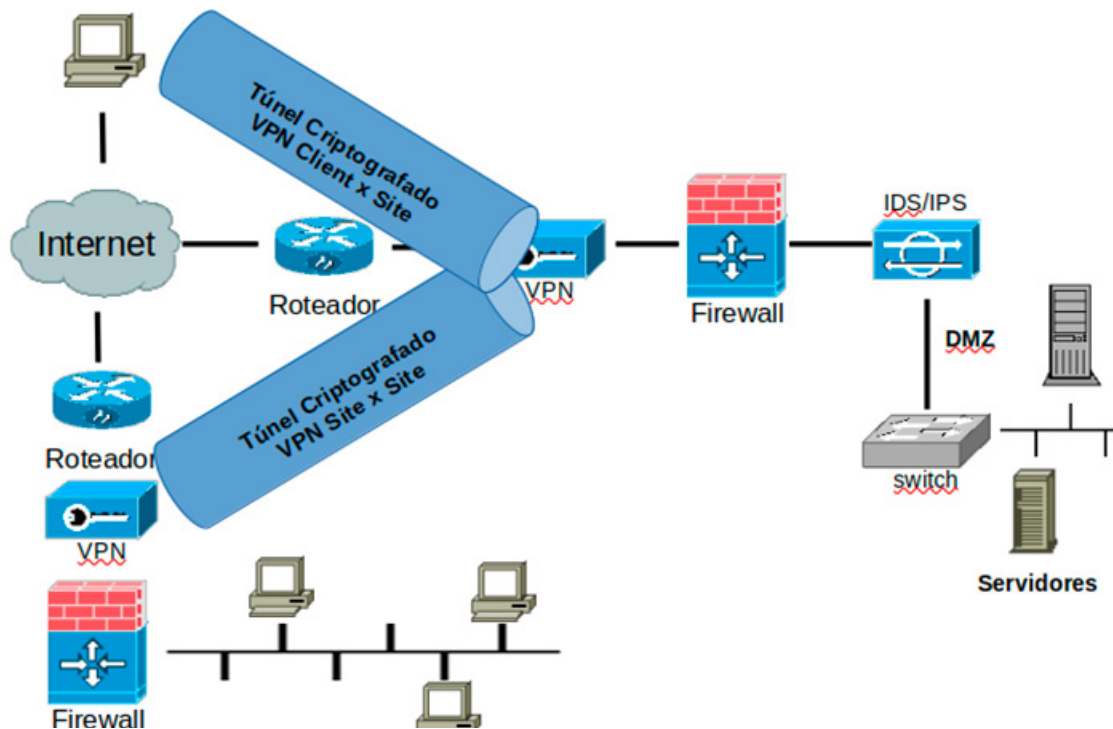


Fonte: elaboração própria (2023).

3.2. VPN (Rede Privada Virtual)

Um concentrador de VPN é usado para fornecer acesso seguro aos recursos da rede interna (intranet) para usuários remotos usando túneis criptografados seguros. A figura 3 mostra um esquema apresentando o acesso a recursos utilizando VPN client x site e site x site.

Figura 3: Acesso via VPN

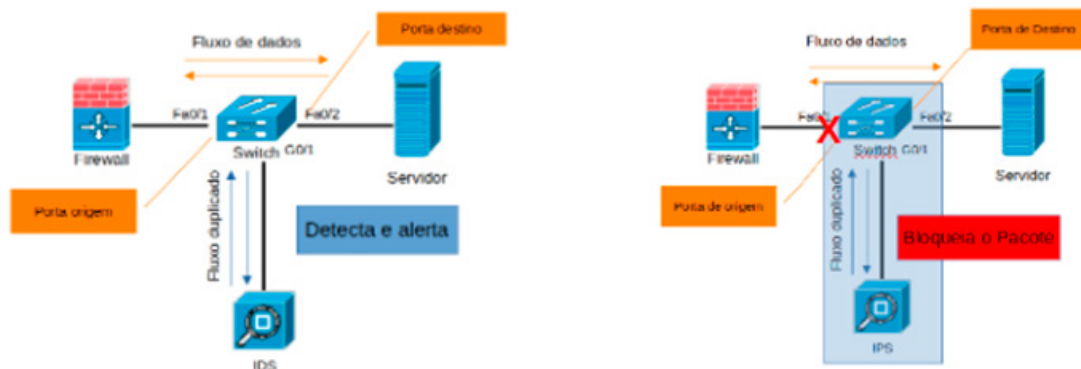


Fonte: elaboração própria (2023).

3.3. Sistemas de Detecção/Prevenção de Intrusão – IDS/IPS

Os ataques podem estar embutidos nos dados. Nesse caso, a proteção deve ir além dos firewalls. Sistemas de detecção/prevenção contra intrusões (IDS/IPS) monitoram o tráfego de entrada à procura de malwares, assinaturas de ataques à rede e muito mais. Caso reconheça uma ameaça, ela pode imediatamente alertar (IDS) ou efetuar seu bloqueio (IPS). A figura 4 mostra esquematicamente o funcionamento de um IDS e de um IPS.

Figura 4: Esquema de funcionamento de um IDS/IPS



Fonte: elaboração própria (2023).

Observe que, para que o IPS possa fazer o bloqueio do pacote contendo o conteúdo malicioso, ele deve estar inline com o tráfego, isto é, o tráfego deve passar obrigatoriamente por ele.

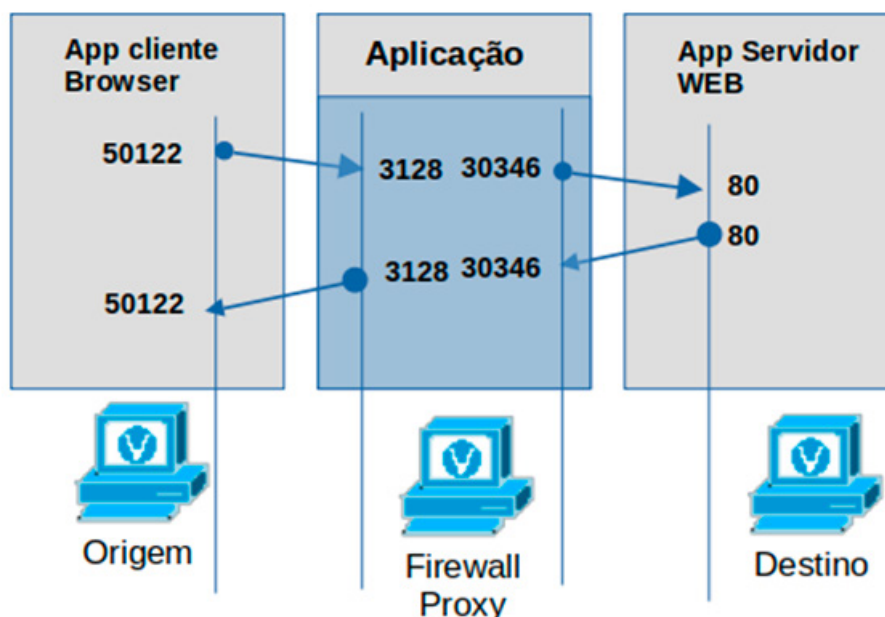
3.4. Firewalls de Aplicação

Atualmente, a maioria dos ataques se dão nas aplicações, tentando explorar vulnerabilidades associadas ao código das aplicações como injeção de SQL (SQL Injection) ou Scripts que são executados do lado do cliente (XSS – Cross site Script), levando a ações em outro site. Um firewall de aplicação atua na camada 7 do modelo OSI, investigando as mensagens dos protocolos usados nesta camada e analisando seu conteúdo.

3.5. Firewall Proxy

Um firewall proxy é um intermediador de conexões, funcionando, para o cliente, como se fosse o servidor, recebendo suas requisições, e, para o servidor, como se fosse o cliente, abrindo uma nova conexão. A figura 5 apresenta o funcionamento de um firewall proxy.

Figura 5: Firewall Proxy



Fonte: elaboração própria (2023).

Uma vez que as conexões são intermediadas no Proxy, algumas funcionalidades podem ser implementadas, como:

- inspecionar o conteúdo utilizando antivírus;
- efetuar controle de navegação Web;
- autenticar o usuário para conceder acesso à internet;
- contabilizar dados do acesso à internet;
- efetuar balanceamento de carga em proxys reversos.

3.6. Segurança de E-mail (ESA) e Controle de Navegação Web (WSA)

Os ESA (Email Security Appliance) são dispositivos de segurança de e-mail que filtram spam e e-mails suspeitos. Já os WSA (Web Security Appliance) filtram sites de malware conhecidos e suspeitos na internet, permitindo que o acesso à web seja monitorado e controlado.

4. Mitigando Riscos nos Dispositivos Finais

Além da segurança da rede como um todo, precisamos nos preocupar com a segurança dos dispositivos finais (Endpoint Security), isto é, dos servidores e estações de trabalho, dos dispositivos intermediários e dos próprios dispositivos de segurança. Para isso, uma série de ações podem ser efetuadas.

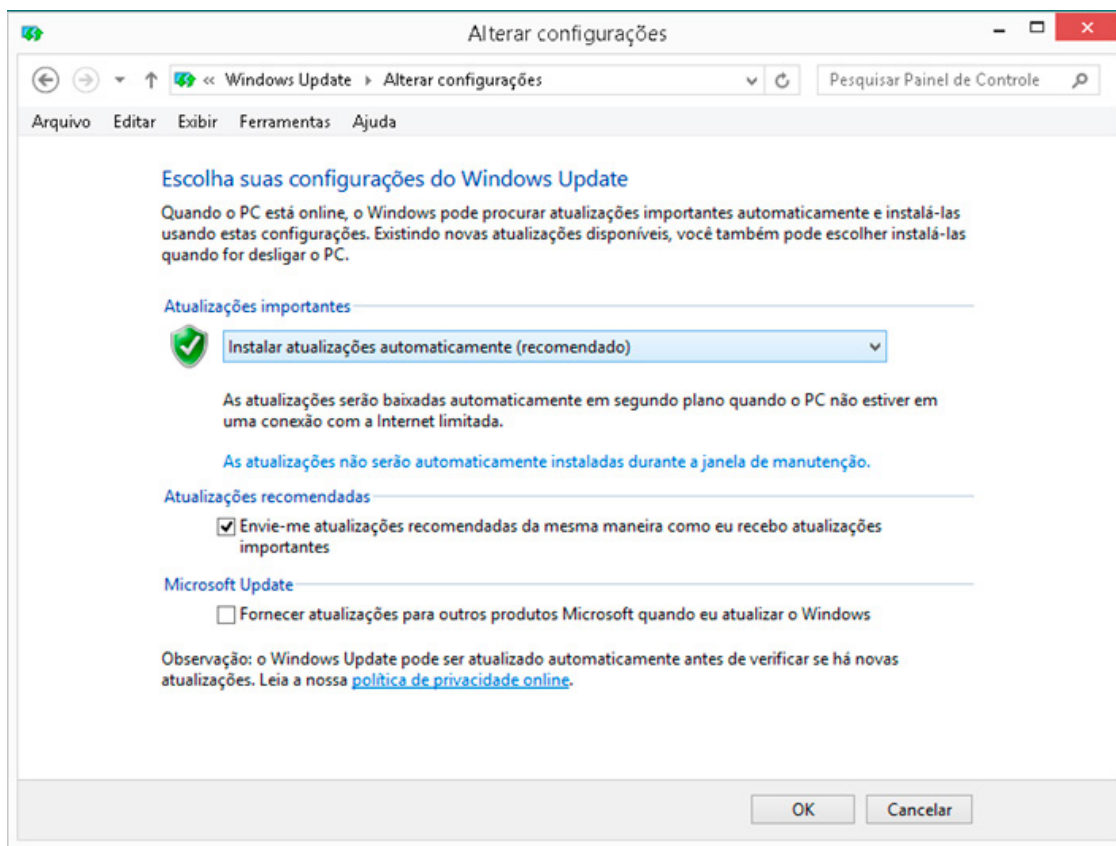
4.1. Cópias de Segurança – Backups

Fazer cópias de segurança de configurações e dados do dispositivo é uma das maneiras mais eficazes de se proteger contra a perda de dados. O backup de dados armazena uma cópia das informações de um computador ou dispositivo em uma mídia removível, que pode ser guardada em um local seguro e deve ser realizada regularmente, conforme identificado na política de segurança. As cópias de backup devem ser protegidas por senha e testadas regularmente para garantir sua eficácia na hora da recuperação.

4.2. Atualização e Correção de Software

Sistemas operacionais e aplicativos devem ser mantidos atualizados sempre que possível, novos recursos e correções são lançados com frequência pelos fabricantes. Antes de serem aplicadas atualizações e correções, estas devem ser testadas e aprovadas, de forma a evitar o impacto de falhas que possam causar em outros sistemas. Antivírus devem ter suas bases sempre atualizadas na versão mais nova. Nas estações de trabalho, é comum configurar para que as atualizações de segurança sejam baixadas e instaladas automaticamente. A figura 6 mostra como configurar um host windows para baixar e instalar automaticamente atualizações de segurança.

Figura 6: Atualizações automáticas no Windows



Fonte: elaboração própria (2023).

4.3. Autenticação, Autorização e Auditoria

Todos os dispositivos de rede devem ser configurados para fornecer acesso seguro apenas a indivíduos autorizados. Servidores de autenticação, autorização e auditoria (AAA ou “triplo A”) fornecem a estrutura centralizada para configurar o controle de acesso nos dispositivos, assim podemos controlar quem tem permissão para acessar uma rede (autenticar), quais ações podem executar (autorizar) e fazer um registro (trilha de auditoria) do que foi feito (auditoria). Este serviço normalmente é fornecido através de servidores RADIUS ou TACACS e serviços de diretório como o Active Directory (AD) da Microsoft. A figura 7 apresenta os principais métodos de autenticação utilizados atualmente.

Figura 7: Fatores de autenticação



Fonte: Cisco NetAcad. Disponível em: <http://netacad.com>. Acesso em: 10 nov. 2023.

Para autenticação, podem ser usadas senhas, menos seguras (aquilo que você sabe), um token (aquilo que você tem) normalmente utilizado na autenticação de dois fatores, biometria (aquilo que você é). Por isso, o mais seguro é uma combinação (dois fatores) destes três métodos.

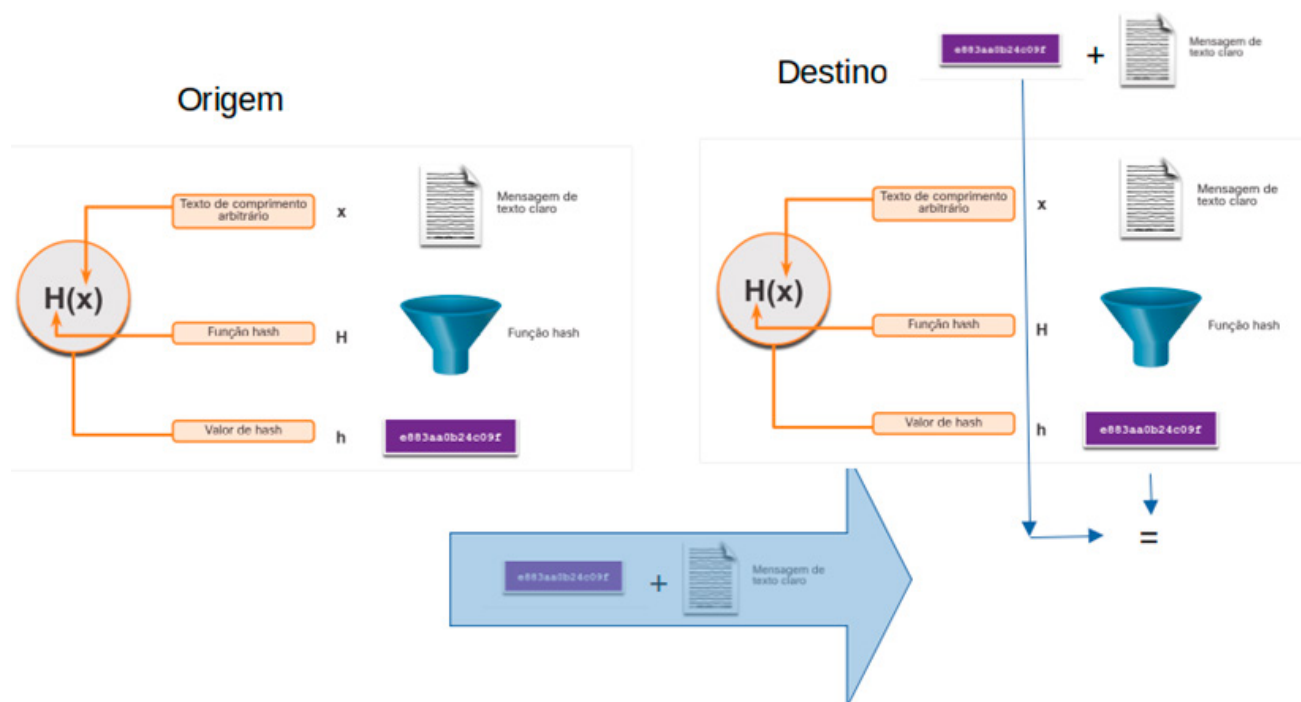
5. Criptografia, Criptologia e Criptoanálise

A criptografia, do grego *kryptos* (escondido, oculto) mais *grápho* (grafia, escrita), é um processo de transformar um texto claro em um texto cifrado, a fim de garantir sua confidencialidade. Já a criptoanálise é a ciência que estuda os textos cifrados, buscando sua decomposição, isto é, a quebra da chave criptográfica. Podemos definir a Criptologia como a ciência que estuda os processos e os algoritmos de Criptografia e Criptoanálise. Apesar de o objetivo principal ser a confidencialidade dos dados, a aplicação das técnicas e algoritmos de criptografia podem garantir também a integridade e a autenticidade dos dados.

5.1. Integridade (Hash Criptográfico)

Um Hash é o resultado de uma função matemática unilateral, isto é, não pode ser revertida. É como moer café ou trigo. Podemos do grão fazer o pó ou a farinha, mas não podemos da farinha reconstituir o grão. Uma função Hash **$h = H(x)$** produz um valor único de tamanho fixo para cada entrada de texto independente do seu tamanho. A figura 8 apresenta a aplicação da função Hash em um texto qualquer.

Figura 8: Função Hash



Fonte: Adaptado de Cisco NetAcad (2023). Disponível em: <http://netacad.com>. Acesso em: 10 nov. 2023.

O exemplo na figura resume o processo matemático. Uma função hash criptográfica deve ter as seguintes propriedades:

- a entrada pode ser de qualquer comprimento;
- a saída tem um comprimento fixo;
- $H(x)$ é relativamente fácil de calcular para qualquer x ;
- $H(x)$ é um caminho e não reversível;
- $H(x)$ é livre de colisões, o que significa que dois valores de entrada diferentes resultarão em valores de hash diferentes.

Assim, as funções de hash são usadas para garantir a integridade de uma mensagem, garantindo que os dados não foram alterados de forma acidental ou intencional. O algoritmo de hash funciona da seguinte forma:

- o dispositivo de origem insere a mensagem em um algoritmo de hashing e calcula seu hash de comprimento fixo de **4ehiDx67NMop9**;
- esse hash é anexado à mensagem e enviado ao destinatário. A mensagem e o hash estão em texto sem formatação;
- o dispositivo receptor remove o hash da mensagem e insere a mensagem no mesmo algoritmo de hash. Se o hash calculado for igual ao que está anexado à mensagem, a mensagem não foi alterada durante o trânsito. Se os hashes não forem iguais, conforme mostrado na figura, a integridade da mensagem não será mais confiável.

Os principais algoritmos de Hash utilizados são:

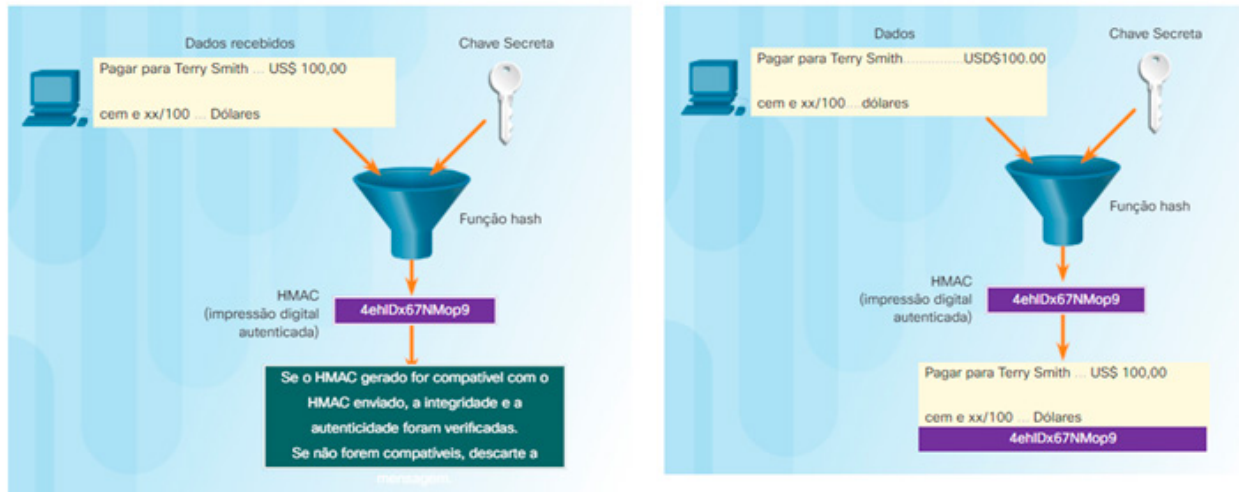
- **MD5 (Message Digest) de 128 bits** – desenvolvido por Ron Rivest e usado em uma variedade de aplicações de internet, MD5 é uma função unidirecional que produz uma mensagem hash de 128 bits. MD5 é considerado um algoritmo legado e deve ser evitado e usado apenas quando não houver alternativas melhores disponíveis. Recomenda-se que SHA-2 ou SHA-3 sejam usados em vez disso.
- **SHA-1** – desenvolvido pela Agência de Segurança Nacional dos EUA (NSA) em 1995. É muito semelhante às funções hash MD5. Existem várias versões. O SHA-1 cria uma mensagem de 160 bits e é um pouco mais lento que o MD5. O SHA-1 possui falhas conhecidas e é um algoritmo legado também.
- **SHA-2** – desenvolvido pela NSA. Inclui SHA-224 (224 bits), SHA-256 (256 bits), SHA-384 (384 bits) e SHA-512 (512 bits). Se você estiver usando SHA-2, então os algoritmos SHA-256, SHA-384 e SHA-512 devem ser usados sempre que possível.
- **SHA-3** – SHA-3 é o mais novo algoritmo de hash e foi introduzido pelo NIST como uma alternativa e eventual substituição para a família SHA-2 de algoritmos de hash. SHA-3 inclui SHA3-224 (224 bits), SHA3-256 (256 bits), SHA3-384 (384 bits) e SHA3-512 (512 bits). A família SHA-3 são algoritmos de última geração e devem ser usados sempre que possível.

5.2. Autenticação de Origem (HMAC)

Para se combinar autenticação de origem e garantia de integridade, usa-se um código de autenticação de mensagem hash com chave (HMAC), que consiste em uma chave

secreta adicional como entrada à função hash. o HMAC é usado em muitos sistemas, incluindo SSL, IPsec e SSH. A figura 9 apresenta o processo que adiciona a chave HMAC aos algoritmos de Hash.

Figura 9: Autenticação de origem com HMAC



Fonte: Cisco NetAcad. Disponível em: <http://netacad.com>. Acesso em: 10 nov. 2023.

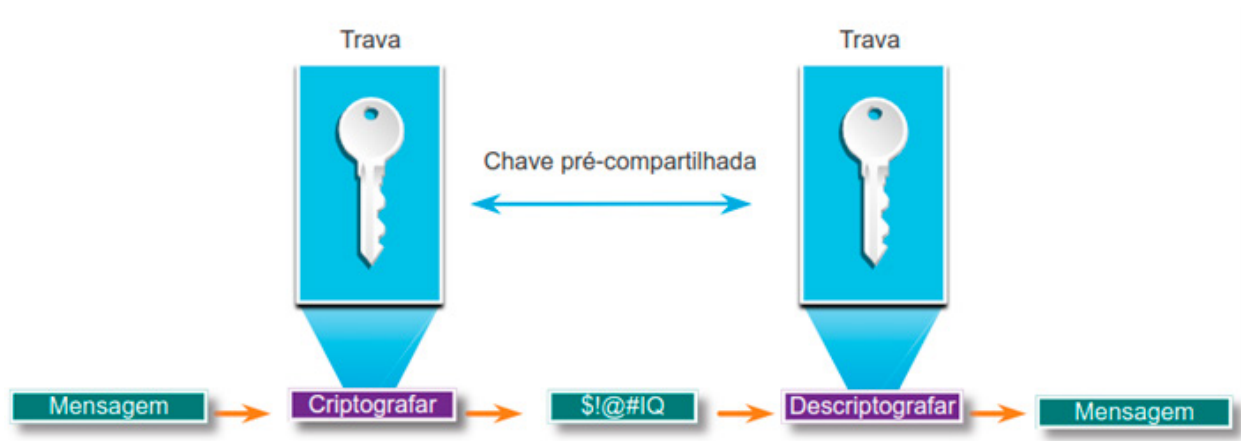
Conforme mostrado na figura, um HMAC é calculado usando um algoritmo criptográfico que combina uma função hash criptográfica com uma chave secreta. As funções de hash são a base do mecanismo de proteção do HMAC. Uma vez que apenas o remetente e o destinatário têm conhecimento da chave secreta e a saída da função hash depende dos dados de entrada e da chave secreta. Apenas as partes que têm acesso a essa chave secreta podem calcular o digest de uma função HMAC. Isso previne os ataques man-in-the-middle e fornece autenticação da origem dos dados.

5.3. Confidencialidade

Existem duas classes de criptografia usadas para fornecer confidencialidade de dados, criptografia assimétrica e criptografia simétrica. A diferença entre elas diz respeito a como as chaves são geradas e trocadas.

Algoritmos de criptografia simétrica, como Data Encryption Standard (DES), 3DES e Advanced Encryption Standard (AES), baseiam-se na premissa de que a chave criptográfica é conhecida pelas partes antes que a mensagem seja cifrada e transmitida. A figura 10 mostra o processo de troca de mensagens utilizando chave simétrica.

Figura 10: Criptografia simétrica



Fonte: Cisco NetAcad. Disponível em: <http://netacad.com>. Acesso em: 10 nov. 2023.

Os principais algoritmos de chave simétrica utilizados são apresentados no quadro 1.

Quadro 1: Algoritmos de criptografia Simétrica

Algoritmos de criptografia simétrica	Descrição
Data Encryption Standard (DES)	Este é um algoritmo de criptografia simétrica legado. Ele usa um comprimento de chave curto que o torna inseguro para a maioria dos usos atuais.
3DES (Triple DES)	O é o substituto do DES e repete o processo do algoritmo DES três vezes. Deve ser evitado, se possível, uma vez que está programado para ser aposentado em 2023. Se implementado, use durações de chave muito curtas.
AES (Advanced Encryption Standard)	AES é um algoritmo de criptografia simétrica popular e recomendado. Ele oferece combinações de chaves de 128, 192 ou 256 bits para criptografar blocos de dados de 128, 192 ou 256 bits.
Software-Optimized Encryption Algorithm (SEAL)	SEAL é uma alternativa mais rápida de algoritmo de criptografia simétrica para AES. SEAL é uma cifra de fluxo que usa uma chave de criptografia de 160 bits e tem um impacto menor na CPU em comparação com outros algoritmos baseados em software.
Algoritmos da série Rivest ciphers (RC)	Este algoritmo foi desenvolvido por Ron Rivest. Diversas variações foram desenvolvidas, mas o RC4 foi o mais prevalente em uso. RC4 é uma cifra de fluxo usada para proteger o tráfego da web. Verificou-se que tem múltiplas vulnerabilidades que o tornaram inseguro. O RC4 não deve ser utilizado.

Fonte: elaboração própria (2023).

A confidencialidade dos dados também pode ser garantida usando algoritmos assimétricos, incluindo Rivest, Shamir e Adleman (RSA) e a infraestrutura de chave pública (PKI). Aqui, tanto o transmissor quanto receptor têm sua própria chave dividida em duas porções: uma pública e uma privada. Apenas a chave pública de cada parte é compartilhada com a outra, o que é criptografado com a chave pública só pode ser descriptografado com a chave privada, e vice-versa. A figura 11 apresenta esse processo.

Figura 11: Chave assimétrica



Fonte: Cisco NetAcad. Disponível em: <http://netacad.com>. Acesso em: 10 nov. 2023.

Quadro 2: Algoritmos de criptografia assimétrica

Algoritmo de criptografia assimétrica	comprimento da chave	Descrição
Diffie-Hellman (DH)	512, 1024, 2048, 3072, 4096	O algoritmo Diffie-Hellman permite que duas partes concordem com uma chave que elas podem usar para criptografar as mensagens que desejam enviar uma para a outra. A segurança desse algoritmo depende da suposição de que é fácil aumentar um número para uma determinada potência, mas difícil calcular qual potência foi usada, dado o número e o resultado.
Padrão de Assinatura Digital (DSS) e Algoritmo de Assinatura Digital (DSA)	512 - 1024	O DSS especifica o DSA como o algoritmo para assinaturas digitais. DSA é um algoritmo de chave pública baseado no esquema de assinatura ElGamal. A velocidade de criação da assinatura é semelhante ao RSA, mas é 10 a 40 vezes mais lenta para verificação.
Algoritmos de criptografia Rivest, Shamir e Adleman (RSA)	512 até 2048	O RSA é para criptografia de chave pública que se baseia na dificuldade atual de fatorar números muito grandes. É o primeiro algoritmo conhecido por ser adequado para assinatura, bem como criptografia. É amplamente utilizado em protocolos de comércio eletrônico e acredita-se ser seguro, dadas chaves suficientemente longas e o uso de implementações atualizadas.
ElGamal	512 - 1024	Um algoritmo de criptografia de chave assimétrica para criptografia de chave pública que se baseia no contrato de chave Diffie-Hellman. Uma desvantagem do sistema ElGamal é que a mensagem criptografada se torna muito grande, aproximadamente o dobro do tamanho da mensagem original e, por esse motivo, é usada apenas para mensagens pequenas, como chaves secretas.
Técnicas de curva elíptica	224 ou superior	A criptografia de curva elíptica pode ser usada para adaptar muitos algoritmos criptográficos, como Diffie-Hellman ou ElGamal. A principal vantagem da criptografia de curva elíptica é que as chaves podem ser muito menores.

Fonte: elaboração própria (2023).

Por serem lentos e consumir muitos recursos, os algoritmos assimétricos geralmente são usados em mecanismos criptográficos de baixo volume, como assinaturas digitais e troca de chaves simétricas. Exemplos de protocolos que usam algoritmos de chave assimétrica incluem:

- **Internet Key Exchange (IKE)** – é um componente fundamental das redes virtuais privadas IPsec (VPNs).
- **Secure Socket Layer (SSL)** – agora isso é implementado como TLS (Transport Layer Security) padrão da IETF.

- **Secure Shell (SSH)** – este protocolo fornece uma conexão segura de acesso remoto a dispositivos de rede.
- **Pretty Good Privacy (PGP)** – este programa de computador fornece privacidade e autenticação criptográficas. É frequentemente usado para aumentar a segurança das comunicações por e-mail.

O gerenciamento de chaves de algoritmos assimétricos tende a ser mais simples que os algoritmos simétricos, porque geralmente uma das duas chaves de criptografia ou descryptografia pode ser tornada pública. A escolha do tipo de criptografia depende da sua aplicação. O quadro 3 apresenta um comparativo de cada uma destas chaves.

Quadro 3: Comparação entre os algoritmos de chave simétrica e assimétrica

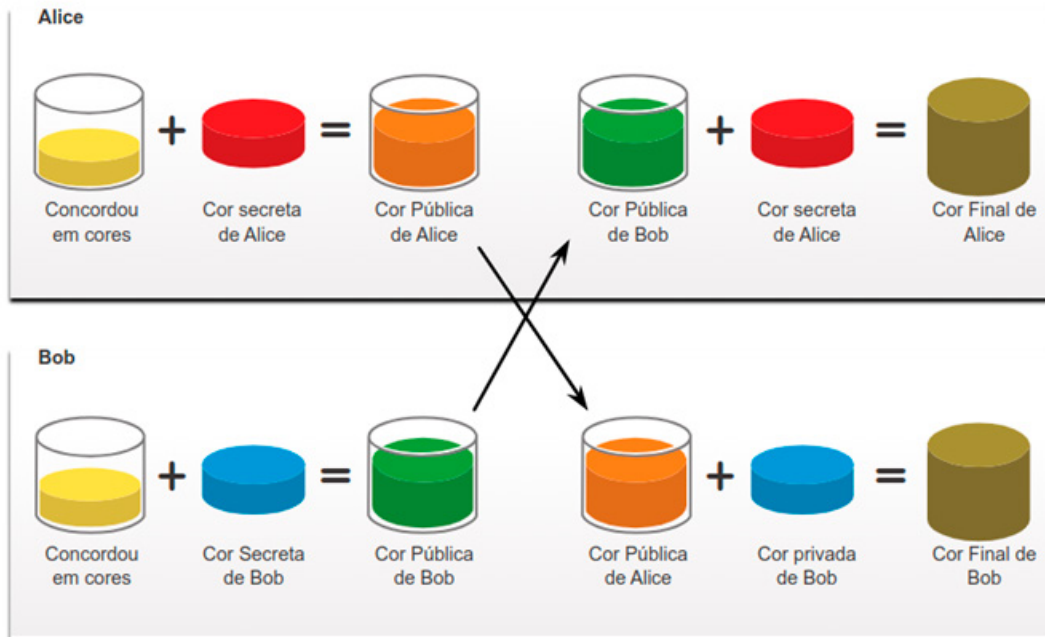
Chave Simétrica	Chave assimétrica
Usa a mesma chave para criptografar e descryptografar os dados	Usa chaves diferentes para criptografar e descryptografar os dados
Comprimento das chaves são menores (40 a 256 bits)	Comprimento das chaves são maiores (256 a 4096 bits)
Mais rápida, exige menos recursos computacionais	Mais lenta, exige mais recursos computacionais
Usada geralmente para criptografar dados em massa. Ex.: VPN	Geralmente utilizado nas transações mais rápidas. Ex.: TLS?SSL

Fonte: elaboração própria (2023).

5.4. Diffie Hellman (DH)

Diffie-Hellman (DH) é um algoritmo assimétrico que permite que dois computadores gerem um segredo compartilhado idêntico (chave simétrica) sem terem se comunicado previamente. A chave compartilhada nunca é realmente trocada entre o remetente e o destinatário. Mas, como as duas partes o conhecem, a chave pode ser usada por um algoritmo de criptografia para criptografar o tráfego entre os dois sistemas. Como exemplo de protocolos que utilizam esse mecanismo estão o IPSEC, o TLS e o SSH. A figura 12 apresenta o funcionamento dos algoritmos DH,

Figura 12: Algoritmos Diddie Helman – DH



Fonte: <http://netacad.com>. Acesso em: 10 nov. 2023.

Nosso exemplo de DH começa com Alice e Bob concordando com uma cor comum arbitrária que não precisa ser mantida em segredo. A cor combinada em nosso exemplo é amarelo.

Em seguida, Alice e Bob selecionam cada um uma cor secreta (chave privada). Alice escolhe vermelho enquanto Bob, o azul. Essas cores secretas nunca serão compartilhadas com ninguém.

Alice e Bob agora misturam a cor comum compartilhada (amarelo) com suas respectivas cores secretas para produzir uma cor pública (chave pública). Alice mistura o amarelo com o vermelho para produzir uma cor pública de laranja. Bob mistura o amarelo e o azul produzindo uma cor pública verde.

Agora ambos trocam suas chaves públicas. Alice envia sua cor pública (laranja) para Bob e Bob envia sua cor pública (verde) para Alice.

Alice e Bob misturam a cor pública que receberam com a sua própria cor secreta original (chave privada) – vermelho para Alice e azul para Bob. O resultado é uma mistura final de cor marrom idêntica para ambos. A cor marrom representa a chave secreta (simétrica) compartilhada resultante entre Bob e Alice.

Considerações Finais da Aula

As estratégias de mitigação envolvem tecnologia, processos e pessoas, que vão desde o uso de ferramentas de detecção e resposta a ataques como Firewalls, IDS/IPS e de acesso seguro como VPNs na adoção de ferramentas ao estabelecimento de uma política de segurança que estabeleça o grau de segurança desejado, passando por procedimentos de backup, atualização e manutenção dos recursos e dispositivos da rede.

Por fim, o uso de métodos de autenticação mais seguros e criptografia utilizados na autenticação de sites e autenticação de dois fatores com uso de tokens ou o uso da biometria procuram tornar as redes mais seguras para os usuários e empresas.

Material Complementar



O que é segurança de endpoint?

2023, AWS.

A segurança dos dispositivos finais é um dos grandes desafios da atualidade. Neste artigo da Amazon, você saberá mais sobre esse conceito, os riscos e os benefícios que sua aplicação traz para as empresas e pessoas.

Link para acesso: <https://aws.amazon.com/pt/what-is/endpoint-security/>

Referências

BARRETO, Jeanine dos Santos *et al.* **Fundamentos de segurança da informação**. Porto Alegre: SAGAH, 2018.

COMER, Douglas E. **Redes de computadores e internet**. 6. ed. Porto Alegre: Bookman, 2016.

FOROUZAN, Behrouz A.; MOSHARRAF, Firouz. **Redes de computadores: uma abordagem top-down**. 1. ed. Porto Alegre: AMGH, 2013.

LACERDA, Paulo Sérgio Pádua de *et al.* **Projeto de redes de computadores**. Porto Alegre: SAGAH, 2022.

MAIA, Luiz Paulo. **Arquitetura de redes de computadores**. 2. ed. Rio de Janeiro: LTC, 2013.

MORAES, Alexandre Fernandes de. **Segurança em redes: fundamentos**. São Paulo: Erica, 2010.

NETWORK ACADEMY. *Introduction to Networks (CCNAv7)*. Disponível em: <https://www.netacad.com/>. Acesso em: 3 jun. 2023.

SOUSA, Lindeberg Barros de. *Redes de computadores: guia total*. 1. ed. São Paulo: Erica, 2009.

_____. *Administração de redes locais*. 2. ed. São Paulo: Erica, 2020.